

Alessandro Gagliardi

Ingénieur cybersécurité et DevSecOps

alessandro.gagliardi225145@gmail.com | Villeurbanne (69)

github.com/Pazificateur69 | Portfolio : pazificateur69.github.io | Permis B, véhiculé

Lyon, mobilité France, télétravail

PROFIL

Profil cybersécurité généraliste formé sur des environnements de production réels : audit applicatif OWASP, pentest, bug bounty, durcissement Linux, réponse à incident, DevSecOps et conformité RGPD. Je relie l'analyse de risques aux correctifs et je vérifie qu'ils tiennent dans la durée.

COMPÉTENCES

Sécurité offensive : pentest web, réseau et système, OWASP Top 10, revue de code, bug bounty, OSINT, CTF, Burp Suite, Nmap, Metasploit, Wireshark.

Défense et réponse à incident : durcissement Linux, Wazuh, Suricata, CrowdSec, Fail2ban, ModSecurity et OWASP CRS, Lynis, analyse de logs, veille CVE.

DevSecOps : GitHub Actions, Semgrep, Trivy, Gitleaks, OWASP ZAP, SBOM CycloneDX, Cosign, conteneurs Docker non-root et distroless.

Infrastructure et réseau : Linux, Docker, Proxmox, OPNsense, WireGuard, nftables, Nginx, Plesk, Ansible, Prometheus, Grafana, Centreon, Active Directory, LDAP.

Gouvernance et référentiels : EBIOS Risk Manager, MITRE ATT&CK, CVSS, CWE, RGPD, Zero Trust, threat modeling, PCA et PRA, PKI et X.509.

Développement : Python, Rust, Bash, TypeScript, SQL, PHP et Laravel, Solidity, Next.js, Node.js.

INTELLIGENCE ARTIFICIELLE

Sécurité des modèles de langage : injection de prompt, jailbreak, red teaming de LLM, durcissement des prompts système, fuite de secrets et de données par le prompt.

Ingénierie de prompts : prompts système contraints et vérifiables, garde-fous et validation des sorties, orchestration d'agents, protocole MCP, cloisonnement de périmètre.

IA appliquée à la sécurité : audit de code et triage de vulnérabilités assistés, automatisation de la reconnaissance et du reporting, kill chain agentique mappée MITRE ATT&CK.

Apprentissage adversarial : exemples adversariaux sur classifieurs PyTorch, modèles locaux Ollama et LM Studio pour données confidentielles.

EXPÉRIENCE PROFESSIONNELLE

Alternant cybersécurité et DevSecOps

NetStrategy, agence web et produits SaaS — Feyzin (69) | Septembre 2025 – aujourd'hui

- Référent sécurité du parc applicatif et des serveurs de production de l'agence.
- Audit white-box et dynamique d'un SaaS Angular et Laravel : 45 vulnérabilités classées OWASP, CWE et CVSS, dont une élévation de privilèges CVSS 9.9, des IDOR sur 11 contrôleurs et des secrets exposés. Rapport client et feuille de route de remédiation.
- Sécurisation de trois applications internes : 31 vulnérabilités sur un CRM Next.js, 52 corrections sur 53 sur une application mobile, durcissement d'une application comptable.
- Chaîne DevSecOps GitHub Actions : Semgrep, Trivy, Gitleaks et OWASP ZAP en intégration continue, SBOM CycloneDX, signature Cosign, conteneurs distroless non-root.
- Déploiement d'une infrastructure virtualisée et supervisée : Proxmox, OPNsense, segmentation réseau, supervision Centreon et automatisation Ansible.

Consultant SEO et développeur web

Alertis, stage puis freelance — Chassieu (69) | Août 2024 – Juillet 2025

- Développement et optimisation de sites Shopify et WordPress, automatisation Python et JavaScript, scraping concurrentiel.
- Travail sur la performance web et les Core Web Vitals, en autonomie sur les livrables et la relation client.

Employé polyvalent, vendangeur et pressureur

Grande distribution et Oedoria, secteur viticole | 2023 – 2025

- Rigueur opérationnelle, continuité d'activité et travail d'équipe en environnement contraint.

CYBERSÉCURITÉ DÉFENSIVE

- **Audit et durcissement d'un serveur de production Plesk (NetStrategy)** : 20 risques identifiés et priorisés, dont 6 critiques, documentés en 11 fiches et 3 runbooks réutilisables (SSH, WAF, Docker).
- **Défense en profondeur déployée** : SSH par clé uniquement, ModSecurity et OWASP CRS passés en blocage, CrowdSec et Fail2ban (15 000 adresses IP bannies), 7 ports Docker retirés d'Internet, 9 CVE noyau corrigées à chaud. Score Lynis de 67 à 77.
- **Réponse à incident et suivi** : tentative d'inclusion de fichier sur /.env contenue, règle Nginx anti-dotfiles sur 15 domaines, TLS sortant activé ; persistance des mesures vérifiée deux mois plus tard.

CYBERSÉCURITÉ OFFENSIVE

- **Bug bounty (YesWeHack)** : deux vulnérabilités de criticité haute chez un opérateur télécom — spécification OpenAPI exposée sans authentification et contournement d'authentification.
- **Audit de smart contracts** : concours Code4rena sur un protocole de prêt Rust et Soroban, vulnérabilité moyenne à haute avec preuve de concept exécutable.
- **CTF et laboratoires** : challenge industriel OPC-UA et SCADA sur Root-Me, compromission d'un laboratoire boot2root jusqu'au compte root.

PROJETS RÉALISÉS

NightOwl, framework de pentest open source. Outil Python réunissant dans une seule chaîne la reconnaissance, les tests web et réseau, l'Active Directory et le reporting. 72 modules, validé sur DVWA, Juice Shop et WebGoat.

T3MP3ST, framework offensif piloté par IA. Contribution à un outil où des agents autonomes enchaînent reconnaissance, exploitation et rapport, selon une kill chain mappée MITRE ATT&CK. 90,1 % de réussite sur le benchmark XBEN.

DataForge, système d'information Zero Trust. Projet de fin d'études : le SI complet d'une entreprise fictive sur 7 machines virtuelles. Active Directory, WireGuard, nftables en refus par défaut, Wazuh et Suricata, analyse EBIOS RM.

Gauntlet, exécution de code hostile en bac à sable. Plateforme exécutant du code non fiable dans des conteneurs éphémères : liste blanche d'appels système seccomp, quotas cgroups, fichiers en lecture seule et réseau coupé.

CURS3D, blockchain post-quantique. Blockchain de couche 1 écrite en Rust avec des signatures résistantes au quantique CRYSTALS-Dilithium. Consensus BFT à preuve d'enjeu, machine virtuelle WASM, 31 400 lignes et 145 tests.

Coffre RGPD, stockage chiffré de données personnelles. Données chiffrées en AES-256-GCM dans le navigateur, avec registre des consentements, journal d'audit et effacement par destruction de la clé pour le droit à l'oubli.

AuditorKit, méthodologie d'audit de smart contracts. Kit de revue de code Solidity : 26 modules d'analyse, checklist de 80 classes de vulnérabilités connues et preuves de concept jouant des exploits historiques.

AEDSC, stablecoin déployé en production. Jeton ERC-20 indexé sur le dirham des Émirats, déployé et vérifié publiquement sur Arbitrum One. Proxy évolutif OpenZeppelin, oracle Chainlink et tests de sécurité Hardhat.

FORMATION

Mastère Cybersécurité (Bac+5) — 1re année en cours. Guardia Cybersecurity School, Lyon. 2026 – 2028. Rythme d'alternance : 3 semaines en entreprise / 1 semaine à l'école.

Titre RNCP niveau 6 — Administrateur d'Infrastructures Sécurisées. RNCP37680, Ministère du Travail. Obtenu en 2026.

Bachelor Cybersécurité, niveau Bac+3. Guardia Cybersecurity School, Lyon. 2023 – 2026. Diplômé.

Baccalauréat général. Mathématiques, physique-chimie, mathématiques expertes. 2023.

LANGUES ÉTRANGÈRES

Anglais : C1 (TOEIC) — Italien : B2 — Russe : notions